Platform module risk register

Prepared 8 September 2026. Six current observations below; none is a claim of a measured production incident. P1 means early correction/validation priority for material exposure; P2 means planned workflow/scope improvement. Priority is not a measured financial loss.

PM-FIN-001 — Finance summary aggregates are bounded by display-oriented row caps

CONFIRMED_SOURCE_DEFECT · P1. Confidence: High for source behavior; affected tenant population unmeasured. Likelihood: Conditional on population exceeding the caps; prevalence unknown.

Evidence: services/finance/finance-dashboard.service.ts:568; line 697; line 742; line 766.

Trigger: More than 250 eligible orders or 100 active counterparties in the requested scope.

Expected: Summary totals and counts represent the complete declared population; paginated detail rows have an independent query.

Observed: The service fetches capped order/customer/supplier sets and derives revenue and receivable/payable summary values from those arrays. The selected finance test covers payroll forecast proof, not overflow populations.

Cause / uncertainty: Summary computation and display data reuse the same bounded read arrays.

Consequences: Cash planning, aging, working capital and profitability can omit obligations or revenue and lead operators to incorrect decisions. No monetary loss or production incident was measured.

Existing mitigation: Organization filters and some explicit payroll proof states exist; they do not restore omitted rows.

Correction: Use scoped decimal database aggregates and separate detail pagination; bind totals to a consistent snapshot and explicit operational/accounting basis.

Acceptance: Fixtures with 251 orders and 101 customers/suppliers retain complete totals; pagination does not alter KPIs; export and detail reconcile.

Owner / estimate: Finance/data engineering with treasury controller; 3–6 engineering days after the metric contract; production data investigation separately sized. Estimates are planning judgments, not booked capacity.

Data and rollout: Recompute impacted views and identify exported/relied-upon reports; do not manufacture journal corrections for a read-model defect.

Related earlier work: ACC-014, ACR-21

PM-ANA-001 — Business Pulse includes draft orders and defaults the displayed currency to XAF

CONFIRMED_SOURCE_DEFECT · P1. Confidence: High for query/composition path. Likelihood: Conditional on draft/non-XAF/time-boundary usage; observed tenant frequency unknown.

Evidence: services/analytics/sales-analytics.service.ts:165; line 143; line 631; line 647.

Trigger: An eligible location contains a draft order, or a non-XAF organization opens Business Pulse.

Expected: Recognized sales, currency and business-day boundaries come from reviewed tenant/source policy; drafts are not described as completed sales.

Observed: The sales read excludes only CANCELLED, sums the remaining order totals, and the runtime Business Pulse caller omits currency when composing output; composition defaults to XAF. Date boundaries also use server-local start/end-of-day helpers.

Cause / uncertainty: Generic order aggregation is reused for an authoritative-sounding sales KPI and runtime context is incomplete.

Consequences: Operators may treat unfinalized demand as revenue or read the wrong currency, propagating incorrect signals into priorities and management decisions.

Existing mitigation: A blocked-state composer and composition test exist; the selected test supplies precomputed summary values and does not exercise source population or tenant currency resolution.

Correction: Reuse the existing analytical context work; define recognized event/returns/cutoff policy, resolve tenant currency and add source-to-UI fixtures.

Acceptance: Completed 100 plus draft 900 yields recognized sales 100 under the agreed policy; non-XAF and local-midnight fixtures retain correct labels and periods.

Owner / estimate: Analytics engineering and metric owner; 3–6 engineering days after policy agreement. Estimates are planning judgments, not booked capacity.

Data and rollout: Review affected dashboards/exports and downstream signals; retain source transactions unchanged.

Related earlier work: STQ-RM-001, historical F1

PM-HR-001 — HR approval requires a technical evidence-hash field

CONFIRMED_SOURCE_UX_GAP · P2. Confidence: High for current field; user failure rate unmeasured. Likelihood: The field is present; frequency and severity of real user friction require task observation.

Evidence: components/hris/HrisApprovalInbox.tsx:353; services/hris/approval-inbox.service.ts:68.

Trigger: An HR approver reviews an item through the approval inbox.

Expected: The approver reviews understandable source facts; the server binds the exact revision and proof digest.

Observed: The current UI presents an Approval evidence hash input. The API accepts evidence data as part of approval; selected tests establish parts of the separation-of-duties and redaction contract, not usability of producing a hash.

Cause / uncertainty: An implementation-level proof representation is exposed as an operator input.

Consequences: Users may abandon the flow, copy an unrelated hash or require developer assistance. This is a usability/control-quality exposure, not demonstrated approval forgery.

Existing mitigation: Domain decision eligibility and scoped/redacted inbox tests pass.

Correction: Resolve evidence server-side and show source revision, differences, decision reason and receipt while retaining maker-checker rules.

Acceptance: An HR user completes approval without manually generating hashes; changed evidence rejects stale approval; unauthorized/self-approval fixtures remain denied.

Owner / estimate: People frontend/domain engineering and HR controller; 2–4 engineering days, plus observed task validation. Estimates are planning judgments, not booked capacity.

Data and rollout: No automatic historical approval rewrite; investigate questionable old evidence only if independently identified.

Related earlier work: STQ-RM-007, historical F4

PM-CACHE-001 — Several sensitive query families omit tenant or actor identity

CREDIBLE_RISK_REQUIRES_RUNTIME_VALIDATION · P1. Confidence: High for missing key dimensions; cross-session disclosure not demonstrated. Likelihood: Depends on client lifetime and identity-transition behavior; unmeasured.

Evidence: hooks/payments/usePaymentReconciliationDashboard.ts:19; hooks/payroll/usePayrollWorkbench.ts:16; hooks/finance/useFinanceDashboard.ts:7; hooks/posHooks/useOfflineSync.ts:75; lib/providers/query-provider.tsx:14.

Trigger: Organization, actor, permissions or entitlements change while the QueryClient survives.

Expected: Scope-changing transitions cannot render old protected results; result-changing scope belongs in cache identity with cancellation/removal where necessary.

Observed: Payment and payroll keys use fixed prefixes (and limits/IDs); finance/offline keys include filters but no explicit tenant/actor. QueryProvider creates one client with useState. This review did not execute every identity-change path or establish whether navigation remounts/clears it.

Cause / uncertainty: Server-inferred authority is not represented explicitly in these client keys.

Consequences: Stale financial or personnel data may be shown in the wrong context if the client survives. Severity justifies early validation, but this is not a confirmed disclosure incident.

Existing mitigation: Server actions retain authorization and some keys have location/run filters; full reloads could clear caches but are not a complete demonstrated contract.

Correction: Trace every switch/logout/revocation path, then centralize scoped keys and query cancellation/removal; avoid retaining previous protected data across authority changes.

Acceptance: Same-browser two-tenant/actor tests show no old values during loading, errors or revocation; all impacted views refresh after writes.

Owner / estimate: Shared frontend/IAM owner plus affected module owners; 2–3 days to validate; 3–7 engineering days if shared lifecycle correction is required. Estimates are planning judgments, not booked capacity.

Data and rollout: No data mutation required; assess exposure only if runtime reproduction identifies it.

Related earlier work: ACC-010, ACR-22

PM-INV-001 — Inventory idempotency-conflict test fails while recording anomaly evidence

CONFIRMED_VERIFICATION_FAILURE · P1. Confidence: High for failing test; deployed defect not established. Likelihood: Reproduced in the local fixture; deployed frequency unknown.

Evidence: services/inventory/**tests**/inventory-stock-event.service.test.ts:431; services/events/business-event-anomaly.service.ts:119; services/inventory/inventory-stock-event.service.ts:692.

Trigger: The focused test reuses a stock event key with a different payload hash.

Expected: A conflicting replay is rejected without stock mutation, and durable conflict evidence survives the required transaction outcome.

Observed: Expected an idempotency-key conflict; received Business-event conflict evidence could not be recorded. The later assertions about stock mutation are not reached after the failed expectation.

Cause / uncertainty: Unresolved interaction between the fixture evidence client and the current anomaly-recording contract.

Consequences: The current verification packet cannot prove this financial/stock retry boundary. A stale test mock is plausible; a real evidence failure must be ruled out.

Existing mitigation: The operation rejects in the observed test; other stock and outbox checks pass. Rejection alone does not establish complete evidence retention.

Correction: Inspect injected versus independent evidence clients, update obsolete fixtures only if confirmed, and add an isolated PostgreSQL replay/rollback scenario before changing runtime logic.

Acceptance: Identical replay is idempotent; changed payload returns the intended safe conflict; quantities/ledger effects stay unchanged and the required conflict evidence is queryable after rollback.

Owner / estimate: Inventory and event-platform engineering; 1–2 engineering days for diagnosis; any runtime fix and DB validation sized after reproduction. Estimates are planning judgments, not booked capacity.

Data and rollout: No stock backfill justified by this test alone. If a real defect is confirmed, investigate source IDs and quantities before authorizing repair.

Related earlier work: ACC-015

PM-SCOPE-001 — Catalog entries and actual workflow evidence need reconciliation

CAPABILITY_EVIDENCE_GAP · P2. Confidence: High for catalog/search result; runtime/deployment scope unverified. Likelihood: Depends on which catalog promises reach users; not measured.

Evidence: services/modules/module-catalog.service.ts:243; line 171; line 255.

Trigger: A buyer or operator treats catalog status and route prefixes as proof of a complete workflow.

Expected: Every offered capability maps to a connected owner, route, data lifecycle and evidence-supported scope; aliases and deferred features are explicit.

Observed: Commercial Agents is available, Presence is available and Content is internal in the catalog. Exact path-name discovery found no presence/commercial-agents/blogs implementation family; HRIS attendance and public landing surfaces do exist elsewhere. This is a search result, not proof of complete absence.

Cause / uncertainty: Declared catalog scope and implementation naming/availability have not been reconciled in this review.

Consequences: False expectations, failed onboarding and entitlement confusion can damage trust. Commission liability or payroll scope must not be inferred from a catalog row.

Existing mitigation: Content is already marked internal; HRIS provides related workforce/time capability.

Correction: Trace aliases and deployment flags, then document supported scope or restrict misleading availability. Do not build speculative CMS/commission systems as part of hardening.

Acceptance: Every advertised catalog row has a verified destination and owner, or an explicit unavailable/internal disposition reflected in UI and commercial material.

Owner / estimate: Module platform and commercial product owners; 1–2 days of discovery; approved product changes separately estimated. Estimates are planning judgments, not booked capacity.

Data and rollout: No business-record changes; preserve existing grants and obligations when correcting availability.

Related earlier work: No earlier work ID assigned.

Shared external evidence gaps

Deployed constraints and data exposure; same-browser identity/cache transitions; concurrent database operations; provider acceptance/settlement; effective country/regime approval; large-population query performance; authenticated accessibility/localization; restore/recovery; actual adoption/support outcomes. These gaps prevent whole-platform readiness claims. Each module plan names the scenarios and accountable roles.